

TRƯỜNG ĐẠI HỌC ĐẠI NAM
KHOA CÔNG NGHỆ THÔNG TIN



BÀI TẬP LỚN

HỌC PHẦN: NHẬP MÔN AN TOÀN, BẢO MẬT THÔNG TIN

ĐỀ TÀI: : BẢO VỆ MẬT KHẨU NGƯỜI DÙNG TRONG CƠ SỞ DỮ LIỆU

Giảng viên: ThS. Đặng Ngọc Ánh

Sinh viên thực hiện: 1. Hà Khánh Huyền – 1871020316
2. Đặng Thị Kiều Loan – 1871020360

Hà Nội, năm 2026

TRƯỜNG ĐẠI HỌC ĐẠI NAM
KHOA CÔNG NGHỆ THÔNG TIN



BÀI TẬP LỚN

HỌC PHẦN: NHẬP MÔN AN TOÀN, BẢO MẬT THÔNG TIN

ĐỀ TÀI: BẢO VỆ MẬT KHẨU NGƯỜI DÙNG TRONG CƠ SỞ DỮ LIỆU

TT	Mã sv	Họ và Tên	Ngày Sinh	Điểm	
				Bảng Số	Bảng Chữ
1	1871020316	Hà Khánh Huyền	22/08/2006		
2	1871020360	Đặng Kiều Loan	19/02/2006		

CÁN BỘ CHẤM THI 2

ThS. Đặng Ngọc Ánh

Hà Nội, năm 2026

PHÂN CÔNG NHIỆM VỤ

STT	MSV	Họ và tên	Nhiệm vụ	Nhận xét của GV	Điểm đánh giá
1	1871020316	Hà Khánh Huyền	Phụ trách phân tích và thiết kế, cài đặt hệ thống Thiết kế cơ sở dữ liệu Mô tả bài toán, cài đặt thuật toán PBKDF2 kết hợp PasswordSalt Tìm kiếm các vấn đề về thuật toán áp dụng và đưa ra giải pháp, lựa chọn công nghệ sử dụng cho dự án phát triển Đưa ra trình thực hiện cho dự án Quản lý mã nguồn trên GitHub Phụ trách viết báo cáo		
2	1871020360	Đặng Thị Kiều Loan	Viết tài liệu hướng dẫn sử dụng phần mềm Kiểm thử phần mềm Xây dựng test case, thực hiện kiểm thử hệ thống và quản lý lỗi		

			Quay và chỉnh sửa video demo Tìm kiếm nội dung, tài liệu tham khảo. Thiết kế slide báo cáo		
--	--	--	--	--	--

MỤC LỤC HÌNH ẢNH

Hình 1.1. Minh họa cơ chế hoạt động của hàm băm SHA	13
Hình 1.2. Minh họa cơ chế mã hóa đối xứng.....	14
Hình 1.3. Minh họa quá trình băm mật khẩu kết hợp salt	15
Hình 1.3. Cài đặt chức năng băm mật khẩu bằng PBKDF2 và salt	27
Hình 1.4. Giao diện đăng ký tài khoản	29
Hình 1.5. Mật khẩu tài khoản mới được lưu dưới dạng hash và salt	29
Hình 1.6. Hệ thống từ chối mật khẩu yếu khi đăng ký.....	31
Hình 1.7. Ghi lại log đăng nhập thành công.	32
Hình 1.8. Tài khoản bị khóa sau nhiều lần đăng nhập sai ở website	33
Hình 1.9. Tài khoản bị khóa sau nhiều lần đăng nhập sai trong database.....	34
Hình 1.10. Nhật ký đăng nhập thành công được lưu trong database	35
Hình 1.11. Giao diện đổi mật khẩu an toàn	36
Hình 1.12. PasswordHash và PasswordSalt được cập nhật sau khi đổi mật khẩu.....	37
Hình 1.13. Hai tài khoản cùng mật khẩu nhưng có salt và hash khác nhau	37

MỤC LỤC

PHÂN CÔNG NHIỆM VỤ.....	3
MỤC LỤC HÌNH ẢNH.....	5
LỜI NÓI ĐẦU.....	8
CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI VÀ CƠ SỞ LÝ THUYẾT	10
1.1. Tổng quan về đề tài	10
1.2. Lý do chọn đề tài	10
1.3. Mục tiêu của đề tài.....	11
1.4. Tổng quan về SHA	12
1.5. Tổng quan về TripleDES	13
1.6. PBKDF2 và Salt	14
1.7. Một số vấn đề gặp phải	15
1.8. Giải pháp	16
CHƯƠNG 2. PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG.....	18
2.1. Mô tả bài toán	18
2.2. Phân tích hệ thống.....	18
2.2.1. Vấn đề bảo mật trong hệ thống cũ	19
2.2.2. Chức năng sau khi nâng cấp	19
2.2.3. Yêu cầu phi chức năng	20
2.3. Các thiết kế trong hệ thống.....	20
2.3.1. Quy trình đăng kí tài khoản	20
2.3.2. Thiết kế quy trình đăng nhập	21
2.3.3. Thiết kế kiểm tra mật khẩu mạnh.....	22
2.3.4. Thiết kế cơ chế khóa tài khoản	23

2.3.5. Thiết kế chức năng ghi log đăng nhập	23
2.3.6. Thiết kế chức năng đổi mật khẩu	24
CHƯƠNG 3. CÀI ĐẶT VÀ KIỂM THỬ HỆ THỐNG	25
3.1. Môi trường thực hiện	25
3.2. Cài đặt và kiểm thử hệ thống.....	25
3.2.1. Chức năng băm mật khẩu	25
3.2.2. Chức năng đăng ký tài khoản	27
3.2.3. Chức năng kiểm tra đăng nhập sai	29
3.2.4. Chức năng kiểm tra đăng nhập đúng.....	31
3.2.5. Cơ chế khóa tài khoản	32
3.2.6. Chức năng lưu nhật kí đăng nhập	34
3.2.7. Chức năng đổi mật khẩu	35
3.2.8. Kiểm thử salt khác nhau giữa các tài khoản.....	37
3.3. Hướng dẫn sử dụng phần mềm.....	37
3.4. Link sản phẩm github.....	39
3.5. Database mẫu.....	39
KẾT LUẬN	52
DANH MỤC TÀI LIỆU THAM KHẢO.....	54

LỜI NÓI ĐẦU

Trong bối cảnh công nghệ thông tin ngày càng phát triển, các hệ thống phần mềm hiện nay hầu hết đều cần đến chức năng đăng ký, đăng nhập và quản lý tài khoản người dùng. Mật khẩu là một trong những yếu tố xác thực phổ biến nhất, đóng vai trò quan trọng trong việc bảo vệ thông tin cá nhân, dữ liệu hệ thống cũng như quyền truy cập của người dùng. Tuy nhiên, nếu mật khẩu không được xử lý và lưu trữ đúng cách, hệ thống có thể đối mặt với nhiều nguy cơ mất an toàn như lộ thông tin đăng nhập, bị dò mật khẩu, tấn công cơ sở dữ liệu hoặc chiếm quyền tài khoản.

Trên thực tế, một số hệ thống đơn giản vẫn lưu mật khẩu dưới dạng rõ trong cơ sở dữ liệu hoặc chỉ sử dụng các thuật toán băm thông thường như SHA-256 để lưu mật khẩu. Cách làm này tiềm ẩn nhiều rủi ro, bởi khi cơ sở dữ liệu bị lộ, kẻ tấn công có thể dễ dàng đọc được mật khẩu hoặc sử dụng các kỹ thuật dò đoán, tra bảng băm, tấn công vét cạn để khôi phục mật khẩu ban đầu. Bên cạnh đó, TripleDES là một thuật toán mã hóa đối xứng, có thể mã hóa và giải mã dữ liệu, nhưng lại không phù hợp để sử dụng như một phương pháp chính trong việc lưu trữ mật khẩu người dùng. Đối với mật khẩu, nguyên tắc an toàn hơn là không cần giải mã lại mật khẩu gốc, mà chỉ cần kiểm tra mật khẩu người dùng nhập vào có khớp với giá trị đã được bảo vệ hay không.

Xuất phát từ yêu cầu đó, đề tài “Modern Password Authentication System - Ứng dụng SHA và TripleDES để bảo vệ mật khẩu người dùng trong cơ sở dữ liệu” được thực hiện nhằm tìm hiểu, phân tích và nâng cấp cơ chế xác thực mật khẩu trong một hệ thống đăng nhập. Trọng tâm của đề tài không chỉ là xây dựng các chức năng cơ bản như đăng ký tài khoản, đăng nhập và lưu thông tin người dùng trong cơ sở dữ liệu, mà còn tập trung vào việc bảo vệ mật khẩu theo hướng hiện đại hơn. Nhóm em tiến hành phân tích hạn chế của việc lưu mật khẩu dạng rõ, việc sử dụng SHA-256 đơn thuần và việc mã hóa mật khẩu bằng TripleDES, từ đó lựa chọn giải pháp phù hợp hơn là sử dụng thuật toán băm mật khẩu chuyên dụng kết hợp với salt.

Thông qua đề tài này, nhóm em có cơ hội củng cố kiến thức về an toàn bảo mật thông tin, đặc biệt là trong lĩnh vực xác thực người dùng và bảo vệ mật khẩu trong cơ sở dữ liệu. Đề tài giúp nhóm em hiểu rõ hơn rằng bảo mật mật khẩu không chỉ đơn giản là che giấu mật khẩu trên giao diện, mà còn liên quan đến cách thiết kế cơ sở dữ liệu, lựa chọn thuật toán phù hợp, kiểm soát hành vi đăng nhập và xây dựng các cơ chế phòng chống tấn công. Đây là những kiến thức có ý nghĩa thực tiễn cao, có thể áp dụng trong quá trình xây dựng và phát triển các hệ thống phần mềm an toàn hơn trong tương lai.

CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI VÀ CƠ SỞ LÝ THUYẾT

1.1. Tổng quan về đề tài

Trong các hệ thống phần mềm hiện nay, chức năng đăng ký và đăng nhập tài khoản người dùng là một trong những chức năng cơ bản nhưng có vai trò rất quan trọng. Thông qua tài khoản và mật khẩu, hệ thống có thể xác định danh tính người dùng, phân quyền truy cập và bảo vệ dữ liệu cá nhân cũng như dữ liệu nghiệp vụ. Tuy nhiên, nếu mật khẩu không được lưu trữ và xử lý an toàn, hệ thống có thể trở thành mục tiêu của nhiều hình thức tấn công như dò mật khẩu, đánh cắp cơ sở dữ liệu, tấn công vét cạn hoặc chiếm quyền tài khoản.

Đề tài “Modern Password Authentication System - Ứng dụng SHA và TripleDES để bảo vệ mật khẩu người dùng trong cơ sở dữ liệu” tập trung nghiên cứu vấn đề bảo vệ mật khẩu trong hệ thống xác thực người dùng. Nội dung chính của đề tài không chỉ dừng lại ở việc xây dựng chức năng đăng ký và đăng nhập, mà còn hướng đến việc phân tích các phương pháp lưu trữ mật khẩu, chỉ ra hạn chế của việc lưu mật khẩu dạng rõ, sử dụng SHA-256 đơn thuần hoặc mã hóa mật khẩu bằng TripleDES, từ đó xây dựng một phương án bảo vệ mật khẩu an toàn hơn.

Trong đề tài này, nhóm em tập trung vào việc nâng cấp cơ chế xác thực mật khẩu theo hướng hiện đại. Hệ thống sau khi nâng cấp sẽ không lưu mật khẩu gốc trong cơ sở dữ liệu. Thay vào đó, mật khẩu được xử lý thông qua thuật toán băm mật khẩu chuyên dụng kết hợp với salt. Ngoài ra, hệ thống còn được bổ sung thêm các chức năng như kiểm tra độ mạnh của mật khẩu, khóa tài khoản sau nhiều lần đăng nhập sai, ghi log đăng nhập thành công hoặc thất bại và đổi mật khẩu an toàn.

1.2. Lý do chọn đề tài

Mật khẩu là phương thức xác thực phổ biến nhất trong nhiều hệ thống phần mềm. Người dùng thường sử dụng mật khẩu để đăng nhập vào website, ứng dụng quản lý, hệ thống thương mại điện tử, mạng xã hội, email hoặc các dịch vụ trực tuyến khác. Vì vậy, nếu mật khẩu bị lộ, người dùng có thể mất quyền kiểm soát tài khoản, đồng thời hệ thống cũng có nguy cơ bị truy cập trái phép.

Một trong những sai lầm phổ biến khi xây dựng hệ thống đăng nhập là lưu mật khẩu trực tiếp dưới dạng rõ trong cơ sở dữ liệu. Đây là cách lưu trữ rất nguy hiểm, không đáp ứng yêu cầu bảo mật cơ bản.

Ngoài ra, một số hệ thống có thể sử dụng hàm băm như SHA-256 để che giấu mật khẩu. Tuy nhiên, nếu chỉ dùng SHA-256 đơn thuần, không có salt và không có cơ chế làm chậm, thì hệ thống vẫn dễ bị tấn công dò đoán bằng cách thử nhiều mật khẩu khác nhau trong thời gian ngắn. Với sự phát triển của phần cứng hiện nay, các thuật toán băm nhanh như SHA-256 không phù hợp để lưu mật khẩu người dùng theo cách trực tiếp.

Bên cạnh đó, TripleDES là thuật toán mã hóa đối xứng, nghĩa là dữ liệu sau khi mã hóa có thể được giải mã trở lại nếu có khóa. Đặc điểm này phù hợp với những trường hợp cần khôi phục dữ liệu ban đầu, nhưng lại không phù hợp để lưu mật khẩu làm phương án chính. Đối với mật khẩu, hệ thống không cần biết mật khẩu gốc của người dùng là gì, mà chỉ cần kiểm tra mật khẩu người dùng nhập vào có đúng hay không.

Xuất phát từ những lý do trên, nhóm em lựa chọn đề tài này nhằm tìm hiểu sâu hơn về cách bảo vệ mật khẩu người dùng trong cơ sở dữ liệu. Đề tài có tính thực tiễn cao, phù hợp với các hệ thống web có chức năng đăng ký, đăng nhập và quản lý tài khoản người dùng.

1.3. Mục tiêu của đề tài

Mục tiêu chính của đề tài là xây dựng và nâng cấp hệ thống xác thực mật khẩu theo hướng an toàn hơn. Hệ thống cần đảm bảo rằng mật khẩu người dùng không được lưu trực tiếp trong cơ sở dữ liệu, đồng thời phải có các cơ chế hỗ trợ nhằm hạn chế nguy cơ bị tấn công.

Các mục tiêu cụ thể của đề tài bao gồm:

- Tìm hiểu vai trò của mật khẩu trong hệ thống xác thực người dùng.
- Phân tích nguy cơ khi lưu mật khẩu dạng rõ trong cơ sở dữ liệu.
- Tìm hiểu đặc điểm của SHA và lý do SHA-256 đơn thuần không phù hợp để lưu mật khẩu.
- Tìm hiểu đặc điểm của TripleDES và lý do TripleDES không phù hợp làm phương pháp lưu mật khẩu chính.

- Xây dựng phương án lưu mật khẩu an toàn hơn bằng PBKDF2 kết hợp với salt.
- Bổ sung kiểm tra độ mạnh của mật khẩu khi đăng ký và đổi mật khẩu.
- Xây dựng cơ chế khóa tài khoản hoặc hạn chế đăng nhập sau nhiều lần nhập sai mật khẩu.
- Ghi lại nhật ký đăng nhập thành công và thất bại để hỗ trợ theo dõi bảo mật.
- Xây dựng chức năng đổi mật khẩu an toàn.
- Kiểm thử hệ thống để chứng minh mật khẩu trong cơ sở dữ liệu không còn ở dạng rõ.

Thông qua các mục tiêu trên, đề tài hướng đến việc xây dựng một hệ thống xác thực mật khẩu có tính ứng dụng thực tế, dễ kiểm thử và phù hợp với yêu cầu của môn học Nhập môn an toàn bảo mật thông tin.

1.4. Tổng quan về SHA

SHA là viết tắt của Secure Hash Algorithm, là nhóm thuật toán băm mật mã được sử dụng để tạo ra giá trị băm có độ dài cố định từ dữ liệu đầu vào. Một đặc điểm quan trọng của hàm băm là tính một chiều. Điều này có nghĩa là từ dữ liệu đầu vào có thể tạo ra giá trị băm, nhưng từ giá trị băm rất khó hoặc gần như không thể khôi phục lại dữ liệu ban đầu bằng phương pháp thông thường.

SHA được sử dụng trong nhiều lĩnh vực của an toàn thông tin như kiểm tra tính toàn vẹn dữ liệu, chữ ký số, xác minh tệp tin và một số cơ chế bảo mật khác. Trong đó, SHA-256 là một biến thể phổ biến, tạo ra giá trị băm có độ dài 256 bit.

Tuy nhiên, SHA-256 không được thiết kế riêng cho việc lưu trữ mật khẩu người dùng. Lý do là SHA-256 có tốc độ xử lý rất nhanh. Tốc độ nhanh là ưu điểm trong các bài toán kiểm tra toàn vẹn dữ liệu, nhưng lại trở thành nhược điểm khi dùng để lưu mật khẩu. Nếu cơ sở dữ liệu chứa mật khẩu đã băm bằng SHA-256 bị lộ, kẻ tấn công có thể thử hàng triệu hoặc hàng tỷ mật khẩu khác nhau để so sánh với giá trị băm. Đây là hình thức tấn công vét cạn hoặc tấn công từ điển.

Ngoài ra, nếu nhiều người dùng có cùng mật khẩu và hệ thống chỉ dùng SHA-256 đơn thuần, thì kết quả băm của các tài khoản đó sẽ giống nhau. Điều này khiến kẻ tấn công dễ dàng nhận biết các tài khoản có cùng mật khẩu. Nếu không sử dụng salt, hệ thống cũng dễ bị tấn công bằng bảng băm có sẵn.

Vì vậy, trong đề tài này, SHA-256 không được sử dụng theo cách đơn thuần để lưu mật khẩu. Thay vào đó, nhóm em sử dụng PBKDF2 kết hợp với salt và hàm băm bên trong để tạo ra cơ chế bảo vệ mật khẩu an toàn hơn. Điểm khác biệt là PBKDF2 có số vòng lặp lớn, làm cho quá trình dò mật khẩu trở nên tốn thời gian hơn rất nhiều so với việc dùng SHA-256 trực tiếp.



Hình 1.1. Minh họa cơ chế hoạt động của hàm băm SHA

1.5. Tổng quan về TripleDES

TripleDES là một thuật toán mã hóa đối xứng được phát triển dựa trên DES. Thay vì mã hóa dữ liệu một lần như DES, TripleDES thực hiện quá trình mã hóa nhiều lần nhằm tăng độ an toàn so với DES ban đầu. Với thuật toán mã hóa đối xứng, cùng một khóa hoặc các khóa liên quan được sử dụng cho quá trình mã hóa và giải mã dữ liệu.

TripleDES từng được sử dụng trong nhiều hệ thống bảo mật, đặc biệt là trong các hệ thống tài chính, thanh toán và truyền dữ liệu. Ưu điểm của mã hóa đối xứng là dữ liệu sau khi mã hóa có thể được giải mã trở lại khi có khóa phù hợp. Tuy nhiên, chính đặc điểm có thể giải

mã này lại khiến TripleDES không phù hợp để làm phương pháp lưu mật khẩu chính trong hệ thống xác thực người dùng.

Đối với mật khẩu, hệ thống không cần giải mã để biết mật khẩu gốc. Khi người dùng đăng nhập, hệ thống chỉ cần kiểm tra mật khẩu nhập vào có đúng với thông tin đã lưu hay không. Nếu sử dụng TripleDES để mã hóa mật khẩu và lưu vào cơ sở dữ liệu, thì khi khóa mã hóa bị lộ, toàn bộ mật khẩu có thể bị giải mã. Đây là rủi ro lớn đối với hệ thống.

Vì vậy, TripleDES phù hợp hơn với những trường hợp cần bảo vệ dữ liệu nhưng vẫn cần khôi phục dữ liệu ban đầu, ví dụ như mã hóa một số thông tin cần giải mã lại khi sử dụng. Còn đối với mật khẩu, giải pháp phù hợp hơn là dùng thuật toán băm mật khẩu một chiều, kết hợp salt và cơ chế làm chậm để hạn chế tấn công dò mật khẩu.

Trong phạm vi đề tài, TripleDES được nghiên cứu để phân tích và so sánh, từ đó làm rõ lý do tại sao không nên dùng mã hóa hai chiều làm phương pháp lưu mật khẩu chính.



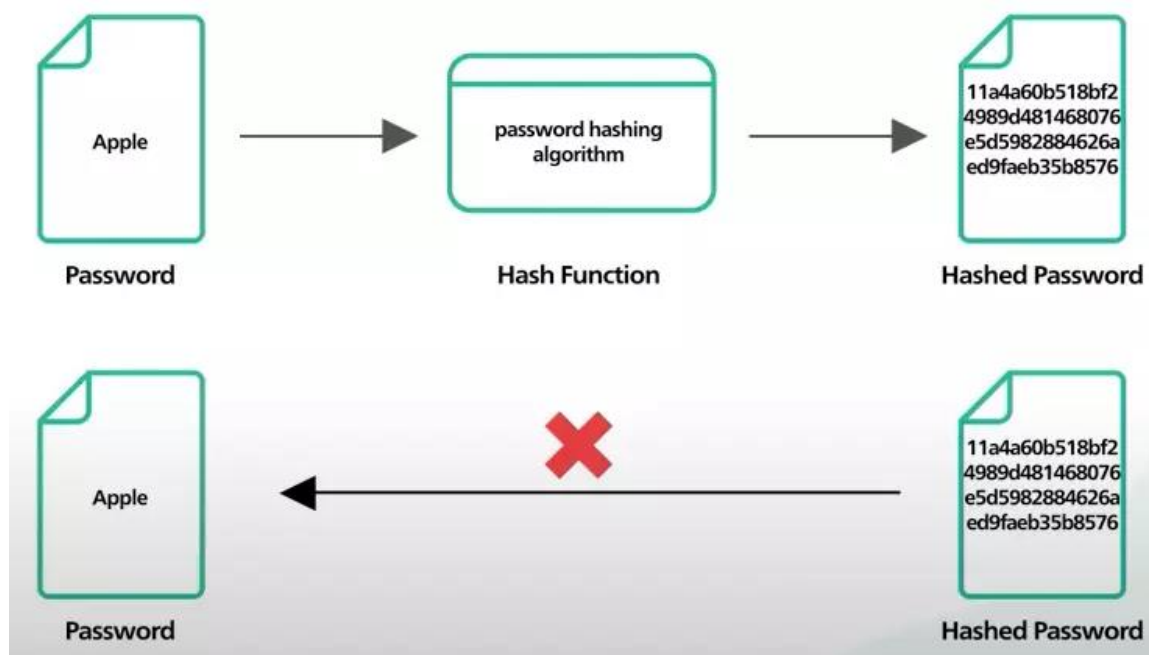
Hình 1.2. Minh họa cơ chế mã hóa đối xứng

1.6. PBKDF2 và Salt

PBKDF2 là viết tắt của Password-Based Key Derivation Function 2. Đây là một thuật toán dẫn xuất khóa từ mật khẩu, thường được sử dụng trong các hệ thống cần bảo vệ mật khẩu. PBKDF2 hoạt động bằng cách kết hợp mật khẩu với một giá trị salt ngẫu nhiên, sau đó thực hiện hàm băm lặp lại nhiều lần để tạo ra kết quả cuối cùng.

Salt là một chuỗi dữ liệu ngẫu nhiên được tạo riêng cho từng tài khoản người dùng. Khi sử dụng salt, ngay cả khi hai người dùng đặt cùng một mật khẩu, kết quả băm được lưu trong cơ sở dữ liệu vẫn khác nhau. Điều này giúp hạn chế việc kẻ tấn công nhận ra các tài khoản có cùng mật khẩu, đồng thời làm giảm hiệu quả của các bảng băm có sẵn.

PBKDF2 còn có ưu điểm là sử dụng số vòng lặp lớn. Số vòng lặp càng cao thì quá trình tạo hash càng tốn thời gian hơn. Điều này không gây ảnh hưởng đáng kể đối với người dùng bình thường khi đăng nhập, nhưng lại làm cho việc tấn công dò mật khẩu trở nên khó khăn hơn. Kẻ tấn công sẽ mất nhiều thời gian hơn để thử từng mật khẩu, từ đó giảm hiệu quả của tấn công vét cạn



Hình 1.3. Minh họa quá trình băm mật khẩu kết hợp salt

1.7. Một số vấn đề gặp phải

Trong quá trình xây dựng hệ thống xác thực, cần nhận diện một số nguy cơ thường gặp liên quan đến mật khẩu. Thứ nhất là tấn công dò mật khẩu, trong đó kẻ tấn công thử nhiều mật khẩu khác nhau để tìm ra mật khẩu đúng. Nếu hệ thống không có cơ chế giới hạn số lần đăng nhập sai, việc dò mật khẩu có thể diễn ra liên tục.

Thứ hai là tấn công từ điển. Đây là hình thức tấn công sử dụng danh sách các mật khẩu phổ biến như “123456”, “password”, “admin123” hoặc các biến thể đơn giản. Nếu người dùng đặt mật khẩu yếu, khả năng bị tấn công thành công sẽ cao hơn.

Thứ ba là tấn công khi cơ sở dữ liệu bị lộ. Nếu mật khẩu được lưu dưới dạng rõ, kẻ tấn công có thể đọc trực tiếp mật khẩu. Nếu mật khẩu chỉ được băm bằng SHA-256 đơn thuần, kẻ tấn công vẫn có thể thử nhiều mật khẩu để tìm giá trị băm tương ứng. Vì vậy, việc sử dụng salt và thuật toán băm mật khẩu chuyên dụng là rất cần thiết.

Thứ tư là nguy cơ dùng lại mật khẩu. Nhiều người dùng có thói quen sử dụng cùng một mật khẩu cho nhiều website khác nhau. Nếu mật khẩu ở một hệ thống bị lộ, kẻ tấn công có thể dùng mật khẩu đó để thử đăng nhập vào các hệ thống khác. Điều này cho thấy trách nhiệm bảo vệ mật khẩu của hệ thống là rất quan trọng.

Để hạn chế các nguy cơ trên, hệ thống cần áp dụng nhiều biện pháp kết hợp, bao gồm yêu cầu mật khẩu đủ mạnh, lưu mật khẩu bằng PBKDF2 kèm salt, khóa tài khoản sau nhiều lần đăng nhập sai và ghi lại nhật ký đăng nhập để phục vụ theo dõi.

1.8. Giải pháp

Từ các phân tích trên, nhóm em lựa chọn hướng xây dựng hệ thống xác thực mật khẩu hiện đại hơn, trong đó PBKDF2 kết hợp salt được sử dụng để bảo vệ mật khẩu người dùng trong cơ sở dữ liệu. Đây là hướng tiếp cận phù hợp với nguyên tắc không lưu mật khẩu dạng rõ và không cần giải mã mật khẩu gốc.

Hệ thống sau khi nâng cấp sẽ xử lý mật khẩu theo quy trình sau: khi người dùng đăng ký, hệ thống kiểm tra độ mạnh của mật khẩu, tạo salt ngẫu nhiên, tạo PasswordHash bằng PBKDF2 và lưu PasswordHash cùng PasswordSalt vào cơ sở dữ liệu. Khi người dùng đăng nhập, hệ thống sử dụng mật khẩu nhập vào cùng salt đã lưu để tạo lại hash, sau đó so sánh với PasswordHash trong database.

Ngoài việc bảo vệ mật khẩu trong database, hệ thống còn được bổ sung thêm các cơ chế hỗ trợ bảo mật. Cụ thể, hệ thống từ chối các mật khẩu yếu, khóa tài khoản sau nhiều lần đăng nhập sai, ghi log đăng nhập thành công hoặc thất bại và cho phép người dùng đổi mật khẩu an

toàn. Những chức năng này giúp hệ thống không chỉ an toàn ở mức lưu trữ dữ liệu, mà còn an toàn hơn trong quá trình vận hành.

Định hướng giải pháp này phù hợp với mục tiêu của đề tài và có thể áp dụng vào các hệ thống web có chức năng đăng ký, đăng nhập và quản lý tài khoản người dùng

CHƯƠNG 2. PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG

2.1. Mô tả bài toán

Trong hệ thống có chức năng đăng nhập, mật khẩu là thông tin quan trọng dùng để xác thực danh tính người dùng. Nếu mật khẩu được lưu trực tiếp trong cơ sở dữ liệu, khi database bị lộ, kẻ tấn công có thể dễ dàng lấy được mật khẩu và sử dụng để đăng nhập trái phép vào hệ thống.

Bài toán đặt ra là cần xây dựng và nâng cấp hệ thống xác thực mật khẩu theo hướng an toàn hơn. Hệ thống vẫn phải đảm bảo các chức năng cơ bản như đăng ký tài khoản, đăng nhập, lưu thông tin người dùng và kiểm tra mật khẩu khi đăng nhập. Tuy nhiên, mật khẩu không được lưu ở dạng rõ, không sử dụng SHA-256 đơn thuần và không sử dụng TripleDES làm phương pháp lưu mật khẩu chính.

Để giải quyết vấn đề trên, hệ thống được thiết kế sử dụng PBKDF2 kết hợp với salt nhằm tạo ra giá trị băm bảo mật cho mật khẩu. Ngoài ra, hệ thống còn được bổ sung cơ chế kiểm tra mật khẩu mạnh, khóa tài khoản sau nhiều lần đăng nhập sai, ghi log đăng nhập và đổi mật khẩu an toàn.

2.2. Phân tích hệ thống

Hệ thống ban đầu đã có các chức năng cơ bản phục vụ việc quản lý tài khoản người dùng. Đã có giao diện đăng ký, đăng nhập, phần xử lý backend và cơ sở dữ liệu SQL Server để lưu thông tin tài khoản.

Bảng tài khoản ban đầu gồm các trường chính như:

- **TaiKhoanId:** mã tài khoản.
- **TenDangNhap:** tên đăng nhập.
- **MatKhau:** mật khẩu.
- **VaiTro:** vai trò của người dùng trong hệ thống.

Ở phiên bản ban đầu, mật khẩu được lưu trong cột MatKhau. Đây là điểm chưa an toàn nếu giá trị mật khẩu được lưu trực tiếp dưới dạng rõ.

Ví dụ, nếu người dùng đặt mật khẩu là “123”, hệ thống cũng lưu đúng giá trị “123” trong database. Điều này gây rủi ro lớn nếu cơ sở dữ liệu bị truy cập trái phép.

Vì vậy, chúng em đã sửa lại và thêm cột MatKhau để không còn lưu mật khẩu thật, thay vào đó sử dụng các trường mới như PasswordHash và PasswordSalt để lưu thông tin mật khẩu đã được bảo vệ.

2.2.1. Vấn đề bảo mật trong hệ thống cũ

Hệ thống cũ khá đơn giản nên tồn tại một số vấn đề bảo mật chính liên quan đến mật khẩu người dùng.

1. Thứ nhất, mật khẩu được lưu ở dạng rõ nên người quản trị cơ sở dữ liệu hoặc kẻ tấn công khi có quyền truy cập database có thể đọc trực tiếp mật khẩu của người dùng.
2. Thứ hai, nếu chỉ sử dụng SHA-256 đơn thuần để băm mật khẩu, hệ thống vẫn chưa đủ an toàn. SHA-256 là thuật toán băm nhanh, phù hợp với kiểm tra toàn vẹn dữ liệu nhưng không phù hợp để lưu mật khẩu nếu không có salt và cơ chế làm chậm. Kẻ tấn công có thể sử dụng tấn công từ điển hoặc vét cạn để dò ra mật khẩu ban đầu.
3. Thứ ba, TripleDES là thuật toán mã hóa đối xứng, có thể mã hóa và giải mã dữ liệu. Tuy nhiên, mật khẩu không nên được lưu theo cách có thể giải mã ngược lại. Nếu khóa mã hóa bị lộ, toàn bộ mật khẩu có thể bị khôi phục.
4. Vì vậy chúng em đã chọn phương pháp chuyển hệ thống sang cơ chế lưu mật khẩu một chiều bằng thuật toán chuyên dụng cho mật khẩu, kết hợp salt riêng cho từng tài khoản.

2.2.2. Chức năng sau khi nâng cấp

- Cho phép người dùng đăng ký tài khoản mới.
- Cho phép người dùng đăng nhập bằng tên đăng nhập và mật khẩu.
- Kiểm tra độ mạnh của mật khẩu khi đăng ký và đổi mật khẩu.

- Không lưu mật khẩu dạng rõ trong cơ sở dữ liệu.
 - Lưu mật khẩu bằng PasswordHash và PasswordSalt.
 - Kiểm tra mật khẩu khi đăng nhập bằng cách băm lại mật khẩu người dùng nhập vào.
 - Ghi nhận số lần đăng nhập sai.
 - Khóa tài khoản tạm thời sau nhiều lần đăng nhập sai.
 - Ghi log đăng nhập thành công và thất bại.
 - Cho phép người dùng đổi mật khẩu an toàn.
- Các chức năng trên giúp hệ thống không chỉ bảo vệ mật khẩu khi lưu trữ, mà còn hạn chế các hành vi dò mật khẩu trong quá trình đăng nhập.

2.2.3. Yêu cầu phi chức năng

- **Tính bảo mật:** mật khẩu không được lưu trực tiếp trong database.
- **Tính toàn vẹn:** dữ liệu tài khoản và log đăng nhập cần được lưu chính xác.
- **Tính dễ sử dụng:** người dùng vẫn có thể đăng ký, đăng nhập và đổi mật khẩu thông qua giao diện quen thuộc.
- **Tính dễ kiểm thử:** hệ thống có thể kiểm tra được mật khẩu đã được hash, salt khác nhau giữa các tài khoản và log đăng nhập được ghi nhận.
- **Tính phù hợp:** giải pháp triển khai phù hợp với hệ thống sử dụng C#, ASP.NET Core MVC và SQL Server.

2.3. Các thiết kế trong hệ thống

2.3.1. Quy trình đăng kí tài khoản

Quy trình đăng ký tài khoản được thiết kế theo hướng không lưu mật khẩu dạng rõ.

- **Khi người dùng đăng ký, hệ thống thực hiện các bước sau:**
 - Người dùng nhập tên đăng nhập, mật khẩu và thông tin cần thiết.

- Hệ thống kiểm tra tên đăng nhập đã tồn tại hay chưa.
- Hệ thống kiểm tra độ mạnh của mật khẩu.
- Nếu mật khẩu yếu, hệ thống từ chối đăng ký và hiển thị thông báo.
- Nếu mật khẩu hợp lệ, hệ thống tạo salt ngẫu nhiên.
- Hệ thống sử dụng PBKDF2 để tạo PasswordHash từ mật khẩu và salt.
- Hệ thống lưu PasswordHash, PasswordSalt và thông tin tài khoản vào database.
- Cột MatKhanh không lưu mật khẩu thật, chỉ ghi trạng thái như “Đã bảo vệ”.

- Quy trình này đảm bảo rằng mật khẩu người dùng nhập vào không được lưu trực tiếp trong cơ sở dữ liệu.

2.3.2. Thiết kế quy trình đăng nhập

Quy trình đăng nhập được thiết kế để kiểm tra mật khẩu mà không cần lưu hoặc giải mã mật khẩu gốc.

- Các bước đăng nhập gồm:

- Người dùng nhập tên đăng nhập và mật khẩu.
- Hệ thống tìm tài khoản theo tên đăng nhập.
- Nếu không tồn tại tài khoản, hệ thống ghi log đăng nhập thất bại.
- Nếu tài khoản đang bị khóa, hệ thống từ chối đăng nhập.
- Nếu tài khoản tồn tại, hệ thống lấy PasswordHash và PasswordSalt trong database.
- Hệ thống dùng mật khẩu người dùng nhập vào kết hợp với salt đã lưu để tạo lại hash.
- Hệ thống so sánh hash vừa tạo với PasswordHash trong database.

- Nếu khớp, người dùng đăng nhập thành công.
 - Nếu không khớp, hệ thống tăng số lần đăng nhập sai và ghi log thất bại.
- Với cách thiết kế này, hệ thống không cần biết mật khẩu gốc của người dùng mà vẫn có thể xác thực đăng nhập.

2.3.3. Thiết kế kiểm tra mật khẩu mạnh

Để hạn chế việc người dùng đặt mật khẩu quá dễ đoán, hệ thống bổ sung chức năng kiểm tra độ mạnh mật khẩu khi đăng ký và đổi mật khẩu.

- Mật khẩu hợp lệ cần đáp ứng các điều kiện cơ bản:

- Có ít nhất 8 ký tự.
- Có chữ hoa.
- Có chữ thường.
- Có chữ số.
- Có ký tự đặc biệt.
- Không trùng hoặc chứa tên đăng nhập.
- Không thuộc danh sách mật khẩu phổ biến như “123456”, “admin123”, “abc123”.

- Ví dụ mật khẩu yếu:

- 123456
- admin123
- abcdef
- abc12345

- Ví dụ mật khẩu hợp lệ:

- Huyen@123
- PetCare@123

- Admin@2026

- Chức năng này giúp giảm nguy cơ bị tấn công dò mật khẩu bằng các mật khẩu phổ biến.

2.3.4. Thiết kế cơ chế khóa tài khoản

Để hạn chế tấn công dò mật khẩu, hệ thống được thiết kế cơ chế khóa tài khoản sau nhiều lần đăng nhập sai.

Khi người dùng nhập sai mật khẩu, hệ thống tăng giá trị SoLanDangNhapSai. Nếu số lần đăng nhập sai đạt giới hạn quy định, ví dụ 5 lần, hệ thống sẽ cập nhật ThoiGianKhóa để khóa tài khoản trong một khoảng thời gian nhất định.

Trong thời gian bị khóa, người dùng không thể tiếp tục đăng nhập dù nhập đúng mật khẩu. Sau khi hết thời gian khóa, người dùng có thể thử đăng nhập lại. Nếu đăng nhập thành công, hệ thống đặt lại số lần đăng nhập sai về 0.

Cơ chế này giúp giảm khả năng kẻ tấn công thử nhiều mật khẩu liên tục trên một tài khoản.

2.3.5. Thiết kế chức năng ghi log đăng nhập

Hệ thống cần ghi lại lịch sử đăng nhập để phục vụ việc theo dõi và kiểm tra bảo mật. Mỗi lần người dùng đăng nhập thành công hoặc thất bại, hệ thống sẽ thêm một bản ghi vào bảng NhatKyDangNhap.

- Thông tin log bao gồm:

- Tên đăng nhập.
- Mã tài khoản nếu có.
- Trạng thái đăng nhập thành công hoặc thất bại.
- Nội dung mô tả.
- Địa chỉ IP.
- Thời gian thực hiện.

- Ví dụ một số nội dung log:

- “Đăng nhập thành công”.
- “Sai mật khẩu”.
- “Tài khoản không tồn tại”.
- “Tài khoản bị khóa do nhập sai quá nhiều lần”.

- Log đăng nhập giúp hệ thống dễ dàng kiểm tra lịch sử truy cập và phát hiện các hành vi bất thường.

2.3.6. Thiết kế chức năng đổi mật khẩu

Chức năng đổi mật khẩu được thiết kế nhằm đảm bảo người dùng có thể cập nhật mật khẩu một cách an toàn.

- Quy trình đổi mật khẩu gồm:

- Người dùng đăng nhập vào hệ thống.
 - Người dùng nhập mật khẩu cũ, mật khẩu mới và xác nhận mật khẩu mới.
 - Hệ thống kiểm tra mật khẩu cũ có đúng không.
 - Hệ thống kiểm tra mật khẩu mới có đủ mạnh không.
 - Nếu thông tin hợp lệ, hệ thống tạo salt mới.
 - Hệ thống tạo PasswordHash mới bằng PBKDF2.
 - Hệ thống cập nhật PasswordHash, PasswordSalt và NgayDoiMatKhau.
 - Người dùng có thể đăng nhập lại bằng mật khẩu mới.
- Việc tạo salt mới khi đổi mật khẩu giúp tăng độ an toàn, tránh việc tiếp tục sử dụng lại dữ liệu bảo vệ mật khẩu cũ.

CHƯƠNG 3. CÀI ĐẶT VÀ KIỂM THỬ HỆ THỐNG

3.1. Môi trường thực hiện

Hệ thống được xây dựng trên nền tảng web với mô hình MVC nhằm tách biệt phần giao diện, xử lý nghiệp vụ và dữ liệu. Việc sử dụng mô hình này giúp quá trình phát triển, bảo trì và nâng cấp hệ thống trở nên rõ ràng hơn.

Môi trường cài đặt của hệ thống bao gồm:

Thành phần	Công nghệ sử dụng
Ngôn ngữ lập trình	C#
Framework	ASP.NET Core MVC
Cơ sở dữ liệu	SQL Server
Công cụ lập trình	Visual Studio
Công cụ quản trị CSDL	SQL Server Management Studio
Giao diện	HTML, CSS, Razor View

Trong hệ thống, cơ sở dữ liệu được sử dụng để lưu thông tin tài khoản người dùng, mật khẩu đã được bảo vệ và lịch sử đăng nhập. Sau khi nâng cấp, mật khẩu không còn được lưu trực tiếp dưới dạng rõ mà được xử lý bằng PBKDF2 kết hợp với salt

3.2. Cài đặt và kiểm thử hệ thống

3.2.1. Chức năng băm mật khẩu

Để bảo vệ mật khẩu người dùng, hệ thống sử dụng class xử lý mật khẩu riêng. Class này có nhiệm vụ tạo salt ngẫu nhiên, tạo giá trị hash từ mật khẩu và kiểm tra mật khẩu khi đăng nhập.

- **Quy trình tạo mật khẩu bảo mật gồm các bước:**

1. Người dùng nhập mật khẩu.
 2. Hệ thống tạo salt ngẫu nhiên.
 3. Hệ thống kết hợp mật khẩu với salt.
 4. Thuật toán PBKDF2 tạo ra giá trị PasswordHash.
 5. Hệ thống lưu PasswordHash và PasswordSalt vào cơ sở dữ liệu.
- Trong cách làm này, mật khẩu gốc của người dùng không được lưu trong database. Khi cần kiểm tra đăng nhập, hệ thống sẽ tạo lại hash từ mật khẩu người dùng nhập vào và salt đã lưu, sau đó so sánh với PasswordHash.

```
using System.Security.Cryptography;

namespace QuanLyChamSocThuCung.Services
{
    4 references
    public static class PasswordHasher
    {
        private const int SaltSize = 16;
        private const int KeySize = 32;
        private const int Iterations = 100000;

        3 references
        public static void CreatePasswordHash(string password, out string passwordHash, out string passwordSalt)
        {
            byte[] salt = RandomNumberGenerator.GetBytes(SaltSize);

            byte[] hash = Rfc2898DeriveBytes.Pbkdf2(
                password: password,
                salt: salt,
                iterations: Iterations,
                hashAlgorithm: HashAlgorithmName.SHA256,
                outputLength: KeySize
            );

            passwordSalt = Convert.ToBase64String(salt);
            passwordHash = Convert.ToBase64String(hash);
        }
    }
    1 reference
}
```

```

1 reference
public static bool VerifyPassword(string password, string storedHash, string storedSalt)
{
    if (string.IsNullOrEmpty(password) ||
        string.IsNullOrEmpty(storedHash) ||
        string.IsNullOrEmpty(storedSalt))
    {
        return false;
    }

    byte[] salt;
    byte[] expectedHash;

    try
    {
        salt = Convert.FromBase64String(storedSalt);
        expectedHash = Convert.FromBase64String(storedHash);
    }
    catch
    {
        return false;
    }

    byte[] actualHash = Rfc2898DeriveBytes.Pbkdf2(
        password: password,
        salt: salt,
        iterations: Iterations,
        hashAlgorithm: HashAlgorithmName.SHA256,
        outputLength: KeySize
    );

    return CryptographicOperations.FixedTimeEquals(actualHash, expectedHash);
}

```

Hình 1.3. Cài đặt chức năng băm mật khẩu bằng PBKDF2 và salt

3.2.2. Đăng ký tài khoản mới

Chức năng đăng ký tài khoản được nâng cấp để đảm bảo mật khẩu người dùng không bị lưu trực tiếp trong cơ sở dữ liệu.

- **Khi người dùng đăng ký, hệ thống thực hiện các bước sau:**

1. Nhận thông tin tên đăng nhập và mật khẩu từ form đăng ký.
2. Kiểm tra tên đăng nhập đã tồn tại trong hệ thống hay chưa.
3. Kiểm tra độ mạnh của mật khẩu.
4. Nếu mật khẩu yếu, hệ thống hiển thị thông báo và không cho đăng ký.
5. Nếu mật khẩu hợp lệ, hệ thống tạo PasswordHash và PasswordSalt.
6. Lưu thông tin tài khoản vào bảng TaiKhoan.

Cột MatKhai không dùng để lưu mật khẩu thật. Hệ thống sẽ lưu trạng thái như “Đã bảo vệ”, còn mật khẩu thực tế được biểu diễn thông qua hai cột PasswordHash và PasswordSalt.

- Kiểm thử

Mục đích: xác nhận hệ thống cho phép tạo tài khoản mới và không lưu mật khẩu dạng rõ.

Nội dung kiểm thử	Dữ liệu thử	Kết quả mong đợi
Đăng ký tài khoản với mật khẩu mạnh	Hà Khánh Huyền / HuyenLoan@123	Đăng ký thành công
Kiểm tra database	Bảng TaiKhoan	Có PasswordHash, PasswordSalt, không lưu mật khẩu thật

Đăng ký tài khoản PETCARE

Tên đăng nhập

Hà Khánh Huyền

Số điện thoại

0336904160

Mật khẩu

••••••••

Mật khẩu phải có ít nhất 8 ký tự, gồm chữ hoa, chữ thường, số và ký tự đặc biệt. Ví dụ: Manh@123

Vai trò

Khách hàng

Đăng ký

Đã có tài khoản? [Đăng nhập](#)

Hình 1.4. Giao diện đăng ký tài khoản

TênĐăngNhap									
	TaiKhoanId	TenDangNhap	MatKhau	VaiTro	PasswordHash	PasswordSalt	SoLanDangNhapSai	ThoiGianKhoa	NgayDc
1	1	admin	Đã bảo vệ	Admin	D2aSwHkP0/7lDgqH2q8AF6xafTNu/zkttX7m9z/yE=	f111qq+HvlggxaGXHvS2tg==	0	NULL	2026-0
2	2	nhanvien	Đã bảo vệ	NhanVien	XsmowBH6w4CRO2gVzigKxp8cJuywnEPcf3SLd1GNywm=	e1o1hNiGQYdg46Kytkjnmw==	0	NULL	2026-0
3	3	khachhang	123	KhachHang	NULL	NULL	0	NULL	NULL
4	4	hh	123	KhachHang	NULL	NULL	0	NULL	NULL
5	5	test1	Đã bảo vệ	KhachHang	PE1e95eJ181Dw1bqlaFx4X+q/bDjVPuYECi9SfHiWHc=	mCnlzgV6XRsl7QTks5cKIA==	0	NULL	2026-0
6	6	test2	Đã bảo vệ	KhachHang	0xE/C6TsAb8+6wKenS+1sliizNrp41TETQ2sxoC64M=	v5OSD1j1o4my+fkQyvmEA==	0	NULL	2026-0
7	7	Hà Khánh Huyền	Đã bảo vệ	KhachHang	1tCwpix/MEeXZgThwDgA0KmYvVISYnthHouWkhjAuP8=	N3tmnbVZBPk+iY11JmiTaA==	0	NULL	2026-0

Hình 1.5. Mật khẩu tài khoản mới được lưu dưới dạng hash và salt

Kết quả: hệ thống tạo tài khoản mới thành công. Mật khẩu không được lưu trực tiếp trong database, thay vào đó được lưu dưới dạng hash và salt.

3.2.3. Đăng nhập sai nhiều lần

Nếu người dùng đặt mật khẩu quá đơn giản, hệ thống bổ sung chức năng kiểm tra độ mạnh mật khẩu khi đăng ký và đổi mật khẩu.

- **Mật khẩu hợp lệ cần thỏa mãn các điều kiện:**

- Có ít nhất 8 ký tự.
 - Có ít nhất một chữ hoa.
 - Có ít nhất một chữ thường.
 - Có ít nhất một chữ số.
 - Có ít nhất một ký tự đặc biệt.
 - Không chứa tên đăng nhập.
 - Không thuộc nhóm mật khẩu phổ biến như 123456, admin123, abc123.
- Chức năng này giúp tăng độ an toàn cho tài khoản ngay từ bước đăng ký, tránh việc người dùng đặt mật khẩu quá dễ đoán.
- **Kiểm thử**

Mục đích : xác nhận hệ thống từ chối các mật khẩu dễ đoán.

Nội dung kiểm thử	Dữ liệu thử	Kết quả mong đợi
Đăng ký với mật khẩu yếu	123456	Hệ thống từ chối
Đăng ký với mật khẩu phổ biến	admin123	Hệ thống từ chối
Đăng ký với mật khẩu không có ký tự đặc biệt	abc12345	Hệ thống từ chối
Đăng ký với mật khẩu mạnh	LoanHuyen@123.	Hệ thống xác nhận thành công

Đăng ký tài khoản PETCARE

Tên đăng nhập

Huyền Loan

Số điện thoại

0356789111

Mật khẩu

.....

Mật khẩu phải có ít nhất 8 ký tự, gồm chữ hoa, chữ thường, số và ký tự đặc biệt. Ví dụ: Manh@123

Vai trò

Khách hàng

Đăng ký

Mật khẩu không hợp lệ vui lòng nhập lại .

Đã có tài khoản? [Đăng nhập](#)

Hình 1.6. Hệ thống từ chối mật khẩu yếu khi đăng ký

Kết quả: hệ thống hiển thị thông báo lỗi và không cho phép đăng ký tài khoản với mật khẩu yếu.

3.2.4. Đăng nhập đúng

- Kiểm thử

Mục đích: xác nhận người dùng có thể đăng nhập bằng tài khoản hợp lệ.

Nội dung kiểm thử	Dữ liệu thử	Kết quả mong đợi
Đăng nhập đúng	Test 4 / Huyen@123.	Đăng nhập thành công
Kiểm tra log	Bảng NhatKyDangNhap	Có log đăng nhập thành công

Results Messages							
	NhatKyId	TaiKhoanId	TenDangNhap	TrangThai	NoiDung	DiaChiIP	ThoiGian
1	1	1	admin	1	Đăng nhập thành công	::1	2026-05-30 16:33:25.960
2	2	NULL	0336904156	0	Đăng nhập thất bại: tài khoản không tồn tại	::1	2026-05-30 16:36:02.707
3	3	NULL	0336904160	0	Đăng nhập thất bại: tài khoản không tồn tại	::1	2026-05-30 16:36:44.050
4	4	9	Test4	1	Đăng nhập thành công	::1	2026-05-30 16:37:00.540
5	5	9	Test4	1	Đăng nhập thành công	::1	2026-06-17 22:09:35.747
6	6	2	nhanvien	1	Đăng nhập thành công	::1	2026-06-17 22:09:48.090

Hình 1.7. Ghi lại log đăng nhập thành công.

Kết quả: hệ thống cho phép đăng nhập và ghi lại log đăng nhập thành công.

3.2.5. Cơ chế khóa tài khoản

- Để hạn chế tấn công dò mật khẩu, hệ thống bổ sung cơ chế khóa tài khoản sau nhiều lần đăng nhập sai.
- Khi người dùng nhập sai mật khẩu, hệ thống tăng giá trị SoLanDangNhapSai. Nếu số lần đăng nhập sai đạt giới hạn quy định, ví dụ 5 lần, hệ thống sẽ cập nhật trường ThoiGianKhoa để khóa tài khoản tạm thời.
- Trong thời gian tài khoản bị khóa, người dùng không thể đăng nhập, kể cả khi nhập đúng mật khẩu. Sau khi hết thời gian khóa, người dùng có thể đăng nhập lại. Nếu đăng nhập thành công, hệ thống đặt lại SoLanDangNhapSai về 0.
- Cơ chế này giúp ngăn chặn việc kẻ tấn công thử liên tục nhiều mật khẩu khác nhau trên cùng một tài khoản.
- **Kiểm thử**
Mục đích: xác nhận hệ thống ghi nhận số lần đăng nhập sai và khóa tài khoản khi vượt quá giới hạn.

Nội dung kiểm thử	Dữ liệu thử	Kết quả mong đợi
Nhập sai mật khẩu nhiều lần	Sai mật khẩu 5 lần	Tài khoản bị khóa
Kiểm tra database	Bảng TaiKhoan	SoLanDangNhapSai tăng, ThoiGianKhoa có dữ liệu
Kiểm tra log	Bảng NhatKyDangNhap	Có log đăng nhập thất bại

The image shows a login interface with a dark teal header. Below the header, there are two input fields: 'Tên đăng nhập' (Username) containing 'phanvien' and 'Mật khẩu' (Password) with a masked input (dots). A teal 'Đăng nhập' (Login) button is positioned below the password field. A pink error message box displays the text: 'Sai mật khẩu lần 5. Tài khoản đã bị khóa 5 phút.' (Wrong password 5 times. Account has been locked for 5 minutes.). At the bottom, there is a link that says 'Chưa có tài khoản? [Đăng ký ngay](#)' (Don't have an account? [Register now](#)).

Hình 1.8. Tài khoản bị khóa sau nhiều lần đăng nhập sai ở website

56	56	8	Loan Huyền	0	Sai mật khẩu lần 1/5. Còn 4 lần thử	::1	2026-05-29 23:34:59.723
57	57	8	Loan Huyền	0	Sai mật khẩu lần 2/5. Còn 3 lần thử	::1	2026-05-29 23:35:09.007
58	58	8	Loan Huyền	0	Sai mật khẩu lần 3/5. Còn 2 lần thử	::1	2026-05-29 23:35:15.657
59	59	8	Loan Huyền	0	Sai mật khẩu lần 4/5. Còn 1 lần thử	::1	2026-05-29 23:35:21.797
60	60	8	Loan Huyền	0	Sai mật khẩu lần 5/5. Tài khoản bị khóa 5 p...	::1	2026-05-29 23:35:26.303
61	61	8	Loan Huyền	0	Tài khoản đang bị khóa. Còn khoảng 5 phút	::1	2026-05-29 23:35:33.560

Hình 1.9. Tài khoản bị khóa sau nhiều lần đăng nhập sai trong database

Kết quả: hệ thống khóa tài khoản tạm thời sau nhiều lần đăng nhập sai, hạn chế nguy cơ dò mật khẩu.

3.2.6. Lưu nhật kí đăng nhập

Hệ thống sử dụng bảng `NhatKyDangNhap` để lưu lại lịch sử đăng nhập của người dùng. Mỗi lần đăng nhập thành công hoặc thất bại, hệ thống sẽ ghi một bản ghi vào bảng này .

- Thông tin log bao gồm:

- Mã tài khoản.
- Tên đăng nhập.
- Trạng thái đăng nhập.
- Nội dung log.
- Địa chỉ IP.
- Thời gian đăng nhập.

- Một số trường hợp được ghi log gồm:

- Đăng nhập thành công.
- Nhập sai mật khẩu.
- Tài khoản không tồn tại.
- Tài khoản bị khóa do đăng nhập sai nhiều lần.

- Việc ghi log giúp hệ thống có thể theo dõi hoạt động đăng nhập, hỗ trợ quản trị viên phát hiện các hành vi bất thường và phục vụ quá trình kiểm thử bảo mật.

150 %

Results Messages

	NhatKyId	TaiKhoanId	TenDangNhap	TrangThai	NoiDung	DiaChiIP	ThoiGian
13	13	1	admin	0	Đăng nhập thất bại: sai mật khẩu lần 1	::1	2026-05-29 08:28:27.577
14	14	1	admin	1	Đăng nhập thành công	::1	2026-05-29 14:38:47.647
15	15	2	nhanvien	1	Đăng nhập thành công	::1	2026-05-29 14:40:23.837
16	16	NULL	0336904160	0	Đăng nhập thất bại: tài khoản không tồn tại	::1	2026-05-29 14:40:28.583
17	17	2	nhanvien	1	Đăng nhập thành công	::1	2026-05-29 14:40:34.270
18	18	NULL	0336904160	0	Đăng nhập thất bại: tài khoản không tồn tại	::1	2026-05-29 14:40:39.717
19	19	NULL	0336904160	0	Đăng nhập thất bại: tài khoản không tồn tại	::1	2026-05-29 14:40:45.237
20	20	2	nhanvien	1	Đăng nhập thành công	::1	2026-05-29 14:40:50.187
21	21	NULL	0336904160	0	Đăng nhập thất bại: tài khoản không tồn tại	::1	2026-05-29 14:40:54.467
22	22	2	nhanvien	1	Đăng nhập thành công	::1	2026-05-29 15:28:58.727
23	23	2	nhanvien	1	Đăng nhập thành công	::1	2026-05-29 15:29:44.723
24	24	NULL	Hà Khánh H...	0	Đăng nhập thất bại: tài khoản không tồn tại	::1	2026-05-29 22:21:41.257
25	25	NULL	Hà Khánh H...	0	Đăng nhập thất bại: tài khoản không tồn tại	::1	2026-05-29 22:21:56.190
26	26	NULL	Hà Khánh H...	0	Đăng nhập thất bại: tài khoản không tồn tại	::1	2026-05-29 22:22:07.043

Query executed successfully. DESKTOP-OUCBUN2\SOLEXPRESS ... DESKTOP-OUCBUN2\Admin ...

Hình 1.10. Nhật ký đăng nhập thành công được lưu trong database

3.2.7. Đổi mật khẩu và đăng nhập lại

Chức năng đổi mật khẩu được xây dựng nhằm cho phép người dùng thay đổi mật khẩu một cách an toàn.

- Quy trình đổi mật khẩu gồm:

- Người dùng đăng nhập vào hệ thống.
- Người dùng nhập mật khẩu cũ.
- Người dùng nhập mật khẩu mới và xác nhận mật khẩu mới.
- Hệ thống kiểm tra mật khẩu cũ có đúng không.
- Hệ thống kiểm tra mật khẩu mới có đủ mạnh không.
- Nếu hợp lệ, hệ thống tạo salt mới.
- Hệ thống tạo PasswordHash mới bằng PBKDF2.
- Cập nhật PasswordHash, PasswordSalt và NgayDoiMatKhau trong database.

- Kiểm thử

Mục đích : xác nhận người dùng có thể đổi mật khẩu an toàn và đăng nhập lại bằng mật khẩu mới.

Nội dung kiểm thử	Dữ liệu thử	Kết quả mong đợi
Nhập mật khẩu cũ đúng	Huyen@123	Hệ thống cho phép đổi
Nhập mật khẩu mới mạnh	HuyenLoan@2026.	Đổi mật khẩu thành công
Đăng nhập bằng mật khẩu cũ	Huyen@123	Đăng nhập thất bại
Đăng nhập bằng mật khẩu mới	HuyenLoan@2026.	Đăng nhập thành công

Xin chào, admin
Đổi mật khẩu
Đăng xuất

Mật khẩu cũ

Mật khẩu mới

Mật khẩu mới phải có ít nhất 8 ký tự, gồm chữ hoa, chữ thường, số và ký tự đặc biệt. Ví dụ: Manh@123

Xác nhận mật khẩu mới

Cập nhật mật khẩu

Hình 1.11. Giao diện đổi mật khẩu an toàn

	TaiKhoanId	TenDangNhap	MatKhau	VaiTro	PasswordHash	PasswordSalt	SoLanDangNhapSai	ThoiGianKhoa
1	1	admin	Đã bảo vệ	Admin	D2aSwhtKpO/7lDgqH2q8AF6xafTNt/zkttX7m9zyE=	f1l1tqq+HvlggxaGXhvs2tg==	0	NULL
2	2	nhanvien	Đã bảo vệ	NhanVien	XsmowBH6w4CRO2gVzigKxp8cJuywnEPcf3SLd1GNywM=	e1o1hNiGQYdg46Kyfkjhrw==	0	NULL
3	3	khachhang	Đã bảo vệ	KhachHang	9YJXvH9ZsMb2/5caulAWeBVH7pXRMjEd3ngHFPj2dE=	eJH8B0qpUm1dsZuhNiequA==	0	NULL
4	4	hh	123	KhachHang	NULL	NULL	0	NULL
5	5	test1	Đã bảo vệ	KhachHang	PE1e95eJ181Dw1bqlaFx4X+q/bDjVPuYECi9SfHiWlc=	mCnlzgV6XRsl7QTks5cKIA==	0	NULL
6	6	test2	Đã bảo vệ	KhachHang	0xE/C6TsaAb8+6wKenS+1siizNrp41TETQ2sxoC64M=	v5OSD1j1o4my+fkQyvmEA==	0	NULL
7	7	Hà Khánh Huyền	Đã bảo vệ	KhachHang	1tCwpix/MEeXZgThwDgA0KmYvVISYnthHauWkhyAuP8=	N3tmnbVZBPk+iY11JmiTaA==	0	NULL
8	8	Loan Huyền	Đã bảo vệ	KhachHang	knazTrdGWZap7yxnGapMQjWEj9MNIbQusIjENBTCDY=	a8cXS4Lp9sfh3ABZMc0MiQ==	5	2026-05-29 23:59:34.5

Hình 1.12. PasswordHash và PasswordSalt được cập nhật sau khi đổi mật khẩu

Kết quả: chức năng đổi mật khẩu hoạt động đúng. Sau khi đổi mật khẩu, hệ thống cập nhật PasswordHash, PasswordSalt và NgayDoiMatKhau.

3.2.8. Kiểm tra salt khác nhau giữa các tài khoản

- Kiểm thử

Mục đích: xác nhận mỗi người dùng có salt riêng. Tạo hai tài khoản khác nhau có cùng mật khẩu, ví dụ:

+ Test6 / Huyềnloan@123.

+ Test7/HuyềnLoan@123.

12	12	Test6	Đã bảo vệ	KhachHang	ZWQjUPT4A0F2fQMFPlicnf4GcSRcYpZC8mi9HJ4uUY=	vY00QGxgWaaOYGB2/k8/3g==	0	NULL
13	13	Test7	Đã bảo vệ	KhachHang	DcQpemtX7qXqTONrxJKI9BGBzEfAwIZrkSchblUDg=	vbW0MNDYedRhUO2s6mTcPg==	0	NULL

Hình 1.13. Hai tài khoản cùng mật khẩu nhưng có salt và hash khác nhau

Kết quả : hệ thống tạo salt riêng cho từng tài khoản, giúp tăng độ an toàn khi lưu mật khẩu.

+ PasswordSalt của hai tài khoản khác nhau.

+ PasswordHash của hai tài khoản cũng khác nhau.

3.3. Hướng dẫn sử dụng phần mềm

Để sử dụng hệ thống xác thực mật khẩu, người dùng thực hiện theo các bước sau:

Bước 1. Khởi động hệ thống

- Mở Visual Studio và chạy dự án ASP.NET Core MVC.
- Đảm bảo SQL Server đang hoạt động và cơ sở dữ liệu đã được kết nối thành công.
- Truy cập hệ thống thông qua trình duyệt web.

Bước 2. Đăng ký tài khoản

- Chọn chức năng **Đăng ký**.
- Nhập tên đăng nhập và mật khẩu.

- Hệ thống sẽ kiểm tra tên đăng nhập đã tồn tại hay chưa và đánh giá độ mạnh của mật khẩu.
- Nếu mật khẩu hợp lệ, hệ thống tạo **PasswordHash** và **PasswordSalt**, sau đó lưu thông tin tài khoản vào cơ sở dữ liệu.

Bước 3. Đăng nhập

- Chọn chức năng Đăng nhập.
- Nhập tên đăng nhập và mật khẩu.
- Hệ thống sử dụng PasswordSalt đã lưu để tạo lại giá trị PasswordHash bằng thuật toán PBKDF2 và so sánh với dữ liệu trong cơ sở dữ liệu.
- Nếu thông tin chính xác, người dùng đăng nhập thành công.

Bước 4. Đổi mật khẩu

- Sau khi đăng nhập, chọn chức năng Đổi mật khẩu.
- Nhập mật khẩu cũ, mật khẩu mới và xác nhận mật khẩu mới.
- Hệ thống kiểm tra tính hợp lệ của mật khẩu mới, tạo Salt mới và cập nhật PasswordHash, PasswordSalt trong cơ sở dữ liệu.

Bước 5. Kiểm tra cơ chế bảo mật

Người dùng có thể thực hiện các thao tác sau để kiểm tra hệ thống:

- Đăng nhập sai nhiều lần để kiểm tra chức năng khóa tài khoản.
- Kiểm tra bảng NhatKyDangNhap để xem lịch sử đăng nhập thành công hoặc thất bại.
- Kiểm tra bảng TaiKhoan để xác nhận mật khẩu được lưu dưới dạng PasswordHash và PasswordSalt, không lưu mật khẩu gốc.

Sau khi thực hiện các bước trên, hệ thống đảm bảo:

- Không lưu mật khẩu dưới dạng rõ trong cơ sở dữ liệu.
- Xác thực người dùng thông qua PBKDF2 kết hợp Salt.

- Kiểm tra độ mạnh của mật khẩu khi đăng ký và đổi mật khẩu.
- Khóa tài khoản sau nhiều lần đăng nhập sai.
- Ghi lại nhật ký đăng nhập để phục vụ quản lý và kiểm tra bảo mật.

3.4. Link sản phẩm github

<https://github.com/Hakhanhhyen/AnToanBaoMat>



3.5. Database mẫu

```
USE QuanLyThuCung
```

```
Go
```

```
SELECT * FROM dbo.TaiKhoan;
```

```

-- Kiểm tra lại bảng log

SELECT * FROM dbo.NhatKyDangNhap;

GO

CREATE DATABASE QuanLyThuCung

USE QuanLyThuCung

Go

CREATE TABLE KhachHang (

    KhachHangId INT IDENTITY(1,1) PRIMARY KEY,

    HoTen NVARCHAR(100),

    DienThoai NVARCHAR(20),

    Email NVARCHAR(100)

);

CREATE TABLE ThuCung (

    ThuCungId INT IDENTITY(1,1) PRIMARY KEY,

    TenThuCung NVARCHAR(100),

    Loai NVARCHAR(50),

    Giong NVARCHAR(50),

    Tuoi INT,

    KhachHangId INT,

    FOREIGN KEY (KhachHangId) REFERENCES KhachHang(KhachHangId)

);

CREATE TABLE DichVu (

    DichVuId INT IDENTITY(1,1) PRIMARY KEY,

```

```

    TenDichVu NVARCHAR(100),

    Gia DECIMAL(18,2),

    MoTa NVARCHAR(255)

);

CREATE TABLE NhanVienThuCung (

    NhanVienId INT IDENTITY(1,1) PRIMARY KEY,

    TenNhanVien NVARCHAR(100),

    DienThoai NVARCHAR(20),

    ChucVu NVARCHAR(50)

);

CREATE TABLE TaiKhoan (

    TaiKhoanId INT IDENTITY(1,1) PRIMARY KEY,

    Username NVARCHAR(50),

    Password NVARCHAR(50),

    Role NVARCHAR(20)

);

CREATE TABLE LichHen (

    LichHenId INT IDENTITY(1,1) PRIMARY KEY,

    ThuCungId INT,

    DichVuId INT,

    NgayHen DATETIME,

    TrangThai NVARCHAR(50),

    FOREIGN KEY (ThuCungId) REFERENCES ThuCung(ThuCungId),

```

```

FOREIGN KEY (DichVuId) REFERENCES DichVu(DichVuId)
);

CREATE TABLE HoSoChamSoc (
    HoSoId INT IDENTITY(1,1) PRIMARY KEY,
    ThuCungId INT,
    LichHenId INT,
    ChanDoan NVARCHAR(255),
    DieuTri NVARCHAR(255),
    GhiChu NVARCHAR(255),
    FOREIGN KEY (ThuCungId) REFERENCES ThuCung(ThuCungId),
    FOREIGN KEY (LichHenId) REFERENCES LichHen(LichHenId)
);

INSERT INTO KhachHang (HoTen, DienThoai, Email) VALUES
(N'Nguyễn Văn An', '0901234567', 'an@gmail.com'),
(N'Trần Thị Bình', '0912345678', 'binh@gmail.com'),
(N'Lê Minh Châu', '0923456789', 'chau@gmail.com');

INSERT INTO ThuCung (TenThuCung, Loai, Giong, Tuoi, KhachHangId) VALUES
(N'Lucky', N'Chó', N'Corgi', 3, 1),
(N'Mimi', N'Mèo', N'Mèo Anh lông ngắn', 2, 2),
(N'Bông', N'Chó', N'Poodle', 4, 1),
(N'Tom', N'Mèo', N'Mèo Ba Tư', 5, 3);

```

```

INSERT INTO DichVu (TenDichVu, Gia, MoTa) VALUES
(N'Khám bệnh',200000,N'Khám tổng quát cho thú cưng'),
(N'Spa thú cưng',150000,N'Tắm và vệ sinh thú cưng'),
(N'Tiêm phòng',100000,N'Tiêm vaccine phòng bệnh'),
(N'Cắt tỉa lông',120000,N'Cắt tỉa và làm đẹp lông');

```

```

INSERT INTO NhanVienThuCung (TenNhanVien, DienThoai, ChucVu) VALUES
(N'Nguyễn Văn Bác','0908888888',N'Bác sĩ thú y'),
(N'Trần Thị Spa','0917777777',N'Nhân viên spa'),
(N'Lê Văn Groom','0926666666',N'Nhân viên cắt tỉa lông');

```

```

INSERT INTO TaiKhoan (TenDangNhap,MatKhau, VaiTro) VALUES
('admin','123','Admin'),
('nhanvien','123','NhanVien'),
('khachhang','123','KhachHang');

```

```

INSERT INTO LichHen (ThuCungId, DichVuId, NgayHen, TrangThai) VALUES
(1,1,GETDATE(),N'Chờ duyệt'),
(2,2,GETDATE(),N'Đã duyệt'),
(3,3,GETDATE(),N'Hoàn thành');

```

```

INSERT INTO HoSoChamSoc (ThuCungId, LichHenId, ChanDoan, DieuTri, GhiChu)
VALUES

```

```

(1,1,N'Cảm lạnh nhẹ',N'Uống thuốc 3 ngày',N'Theo dõi thêm'),
(2,2,N'Ve sinh da',N'Tắm spa',N'Tình trạng tốt'),
(3,3,N'Tiêm phòng đại',N'Tiêm vaccine',N'Tái khám sau 6 tháng');

SELECT * FROM KhachHang

SELECT * FROM ThuCung

SELECT * FROM DichVu

SELECT * FROM LichHen

SELECT * FROM HoSoChamSoc

SELECT * FROM TaiKhoan

-- Đổi Username → TenDangNhap

EXEC sp_rename 'TaiKhoan.Username', 'TenDangNhap', 'COLUMN';


-- Đổi Password → MatKhau

EXEC sp_rename 'TaiKhoan.Password', 'MatKhau', 'COLUMN';


-- Đổi Role → VaiTro

EXEC sp_rename 'TaiKhoan.Role', 'VaiTro', 'COLUMN';

SELECT * FROM TaiKhoan;

-- 1. KHACHHANG

INSERT INTO KHACHHANG (MaKH, TenKH, SDT, Email, DiaChi)

VALUES

('KH001', N'Nguyễn Văn An', '0912345678', 'an@gmail.com', N'12 Trần Phú, Hà Nội'),

('KH002', N'Lê Thị Bích', '0987654321', 'bich.le@gmail.com', N'25 Nguyễn Trãi, Đà Nẵng'),

```

('KH003', N'Trần Quốc Hưng', '0938123456', 'hung.tran@gmail.com', N'80 Lý Tự Trọng, Huế'),

('KH004', N'Phạm Thị Hằng', '0977888999', 'hangpham@yahoo.com', N'35 Hai Bà Trưng, TP.HCM'),

('KH005', N'Vũ Hoàng Nam', '0909123456', 'nam.vu@gmail.com', N'101 Lê Lợi, Cần Thơ'),

('KH006', N'Lý Thị Kim', '0977000555', 'kim.ly@yahoo.com', N'7 Trần Hưng Đạo, Hà Nam');

-- 2. NHANVIEN

INSERT INTO NHANVIEN (MaNV, HoTen, GioiTinh, NgaySinh, SDT, Email, ChucVu, Luong)

VALUES

('NV001', N'Trần Minh Tuấn', N'Nam', '1995-04-10', '0901111222', 'tuan@cafe.vn', N'Pha chế', 7000000),

('NV002', N'Hoàng Thị Mai', N'Nữ', '1998-12-22', '0933444555', 'mai@cafe.vn', N'Thu ngân', 6800000),

('NV003', N'Nguyễn Hữu Phước', N'Nam', '2000-07-01', '0945566778', 'phuoc@cafe.vn', N'Phục vụ', 6200000),

('NV004', N'Lê Minh Tâm', N'Nam', '1997-02-15', '0966123456', 'tam@cafe.vn', N'Pha chế', 7000000),

('NV005', N'Phạm Quỳnh Hoa', N'Nữ', '1996-03-08', '0911223344', 'hoa@cafe.vn', N'Phục vụ', 6200000);

-- 3. MON

INSERT INTO MON (MaMon, TenMon, DonGia, LoaiMon, DonViTinh, TrangThai)

VALUES

('M001', N'Cà phê sữa đá', 25000, N'Cà phê', N'Ly', N'Còn bán'),

('M002', N'Sinh tố xoài', 30000, N'Sinh tố', N'Ly', N'Còn bán'),
 ('M003', N'Khoai tây chiên', 40000, N'Dồ ăn vặt', N'Đĩa', N'Còn bán'),
 ('M004', N'Trà đào cam sả', 32000, N'Trà', N'Ly', N'Còn bán'),
 ('M005', N'Sữa chua nếp cẩm', 28000, N'Tráng miệng', N'Cốc', N'Tạm ngưng'),
 ('M006', N'Cà phê đen nóng', 22000, N'Cà phê', N'Ly', N'Còn bán'),
 ('M007', N'Nước cam tươi', 27000, N'Nước ép', N'Ly', N'Còn bán'),
 ('M008', N'Sinh tố bơ', 35000, N'Sinh tố', N'Ly', N'Còn bán'),
 ('M009', N'Bánh mì pate', 30000, N'Dồ ăn vặt', N'Cái', N'Còn bán');

-- 4. BAN

INSERT INTO BAN (MaBan, TenBan, ViTri, SoChoNgoi, TrangThai)

VALUES

('B001', N'Bàn 1', N'Gần cửa sổ', 2, N'Trống'),
 ('B002', N'Bàn 2', N'Chính giữa', 4, N'Dang sử dụng'),
 ('B003', N'Bàn 3', N'Góc trong', 2, N'Trống'),
 ('B004', N'Bàn VIP', N'Tầng trên', 6, N'Dã đặt trước'),
 ('B005', N'Bàn 5', N'Ngoài sân', 4, N'Trống'),
 ('B006', N'Bàn 6', N'Sát quầy', 2, N'Trống');

-- 5. HOADON

INSERT INTO HOADON (MaHD, NgayLap, MaKH, MaNV, MaBan, TongTien, TrangThai)

VALUES

```
('HD001', '2025-07-01 08:30:00', 'KH001', 'NV002', 'B002', 58000, N'Đã thanh toán'),  
( 'HD002', '2025-07-01 09:15:00', 'KH003', 'NV001', 'B001', 47000, N'Chưa thanh toán'),  
( 'HD003', '2025-07-01 10:00:00', NULL, 'NV003', 'B003', 25000, N'Đã thanh toán'),  
( 'HD004', '2025-07-01 11:00:00', 'KH004', 'NV002', 'B004', 60000, N'Đã thanh toán'),  
( 'HD005', '2025-07-01 12:30:00', 'KH005', 'NV004', 'B001', 90000, N'Chưa thanh toán');
```

-- 6. CTHOADON

```
INSERT INTO CTHOADON (MaHD, MaMon, SoLuong, DonGia)
```

```
VALUES
```

```
('HD001', 'M001', 1, 25000),  
( 'HD001', 'M003', 1, 33000),  
( 'HD002', 'M002', 1, 30000),  
( 'HD002', 'M004', 1, 17000),  
( 'HD003', 'M006', 1, 25000),  
( 'HD004', 'M001', 1, 25000),  
( 'HD004', 'M007', 1, 35000),  
( 'HD005', 'M002', 2, 30000),  
( 'HD005', 'M003', 1, 30000);
```

-- 7. CALAMVIEC

```
INSERT INTO CALAMVIEC (MaCa, TenCa, GioBatDau, GioKetThuc)
```

```
VALUES
```

```
('CA01', N'Ca sáng', '07:00', '11:00'),
```

```
('CA02', N'Ca trưa', '11:00', '15:00'),  
('CA03', N'Ca chiều', '15:00', '19:00'),  
('CA04', N'Ca tối', '19:00', '23:00');
```

-- 8. PHANCONG

```
INSERT INTO PHANCONG (MaNV, MaCa, NgayLam)
```

```
VALUES
```

```
('NV001', 'CA01', '2025-07-01'),  
('NV002', 'CA02', '2025-07-01'),  
('NV003', 'CA03', '2025-07-01'),  
('NV004', 'CA04', '2025-07-01'),  
('NV002', 'CA01', '2025-07-02'),  
('NV005', 'CA03', '2025-07-01'),  
('NV003', 'CA04', '2025-07-02');
```

```
USE QuanLyThuCung;
```

```
GO
```

```
IF COL_LENGTH('dbo.TaiKhoan', 'PasswordHash') IS NULL
```

```
BEGIN
```

```
    ALTER TABLE dbo.TaiKhoan ADD PasswordHash NVARCHAR(MAX) NULL;
```

```
END
```

```
GO
```

```
IF COL_LENGTH('dbo.TaiKhoan', 'PasswordSalt') IS NULL
```

```
BEGIN
```

```
    ALTER TABLE dbo.TaiKhoan ADD PasswordSalt NVARCHAR(MAX) NULL;
```

```
END
```

```
GO
```

```
IF COL_LENGTH('dbo.TaiKhoan', 'SoLanDangNhapSai') IS NULL
```

```
BEGIN
```

```
    ALTER TABLE dbo.TaiKhoan ADD SoLanDangNhapSai INT NOT NULL DEFAULT  
    0;
```

```
END
```

```
GO
```

```
IF COL_LENGTH('dbo.TaiKhoan', 'ThoiGianKhoa') IS NULL
```

```
BEGIN
```

```
    ALTER TABLE dbo.TaiKhoan ADD ThoiGianKhoa DATETIME NULL;
```

```
END
```

```
GO
```

```
IF COL_LENGTH('dbo.TaiKhoan', 'NgayDoiMatKhau') IS NULL
```

```
BEGIN
```

```
    ALTER TABLE dbo.TaiKhoan ADD NgayDoiMatKhau DATETIME NULL;
```

```
END
```

GO

IF OBJECT_ID('dbo.NhatKyDangNhap', 'U') IS NULL

BEGIN

CREATE TABLE dbo.NhatKyDangNhap

(

NhatKyId INT IDENTITY(1,1) PRIMARY KEY,

TaiKhoanId INT NULL,

TenDangNhap NVARCHAR(100) NULL,

ThanhCong BIT NOT NULL,

NoiDung NVARCHAR(255) NULL,

DiaChiIP NVARCHAR(50) NULL,

ThoiGian DATETIME NOT NULL DEFAULT GETDATE()

);

END

GO

-- Xóa dữ liệu bảng

DELETE FROM PHANCONG

DELETE FROM CALAMVIEC

DELETE FROM CTHOADON

DELETE FROM HOADON

DELETE FROM BAN

DELETE FROM MON

DELETE FROM NHANVIEN

DELETE FROM KHACHHANG

KẾT LUẬN

Trong quá trình thực hiện đề tài “Modern Password Authentication System - Ứng dụng SHA và TripleDES để bảo vệ mật khẩu người dùng trong cơ sở dữ liệu”, nhóm em đã tìm hiểu và phân tích các vấn đề liên quan đến bảo vệ mật khẩu trong hệ thống xác thực người dùng. Qua đó, nhóm em nhận thấy rằng việc lưu mật khẩu trực tiếp dưới dạng rõ trong cơ sở dữ liệu là một rủi ro bảo mật nghiêm trọng. Nếu cơ sở dữ liệu bị lộ, kẻ tấn công có thể dễ dàng đọc được mật khẩu và sử dụng để chiếm quyền tài khoản người dùng.

Bên cạnh đó, đề tài cũng giúp nhóm em hiểu rõ hơn về hạn chế của việc sử dụng SHA-256 đơn thuần và TripleDES trong lưu trữ mật khẩu. SHA-256 là hàm băm có tốc độ xử lý nhanh, phù hợp với kiểm tra toàn vẹn dữ liệu nhưng không phù hợp để lưu mật khẩu nếu không có salt và cơ chế làm chậm. TripleDES là thuật toán mã hóa đối xứng, có khả năng giải mã dữ liệu khi có khóa, vì vậy không phù hợp để làm phương pháp lưu mật khẩu chính. Đối với mật khẩu người dùng, hệ thống không nên có khả năng khôi phục lại mật khẩu gốc mà chỉ cần kiểm tra mật khẩu nhập vào có hợp lệ hay không.

Từ những phân tích trên, nhóm em đã nâng cấp hệ thống xác thực mật khẩu theo hướng an toàn hơn bằng cách sử dụng PBKDF2 kết hợp với salt. Khi người dùng đăng ký hoặc đổi mật khẩu, hệ thống không lưu mật khẩu thật vào cơ sở dữ liệu mà tạo ra PasswordHash và PasswordSalt để lưu trữ. Khi đăng nhập, hệ thống sử dụng mật khẩu người dùng nhập vào cùng salt đã lưu để tạo lại giá trị hash và so sánh với dữ liệu trong database. Cách làm này giúp giảm nguy cơ lộ mật khẩu thật nếu cơ sở dữ liệu bị truy cập trái phép.

Ngoài chức năng bảo vệ mật khẩu trong cơ sở dữ liệu, hệ thống còn được bổ sung một số cơ chế bảo mật cần thiết như kiểm tra độ mạnh mật khẩu, từ chối các mật khẩu yếu, ghi log đăng nhập thành công và thất bại, khóa tài khoản tạm thời sau nhiều lần đăng nhập sai và hỗ trợ đổi mật khẩu an toàn. Các chức năng này giúp hệ thống không chỉ an toàn hơn trong việc lưu trữ dữ liệu mà còn hạn chế được các hành vi dò đoán mật khẩu trong quá trình đăng nhập. Kết quả kiểm thử cho thấy hệ thống đã đáp ứng được các yêu cầu chính của đề tài. Người dùng có thể đăng ký tài khoản mới, đăng nhập đúng, hệ thống có thể phát hiện đăng nhập sai nhiều lần, mật khẩu trong cơ sở dữ liệu không còn ở dạng rõ, mỗi tài khoản có salt riêng và

chức năng đổi mật khẩu hoạt động đúng. Điều này chứng minh hệ thống sau khi nâng cấp đã cải thiện đáng kể so với cách lưu mật khẩu thông thường.

Tuy nhiên, hệ thống vẫn còn một số hướng có thể phát triển thêm trong tương lai. Nhóm em có thể bổ sung xác thực hai yếu tố, xác minh email khi đăng ký, CAPTCHA chống bot, cảnh báo đăng nhập bất thường hoặc cho phép người dùng xem lịch sử đăng nhập của tài khoản. Những cải tiến này sẽ giúp hệ thống có mức độ bảo mật cao hơn và phù hợp hơn khi triển khai trong môi trường thực tế.

Thông qua đề tài này, nhóm em đã củng cố được kiến thức về an toàn bảo mật thông tin, đặc biệt là trong lĩnh vực xác thực người dùng và bảo vệ mật khẩu. Đề tài giúp nhóm em hiểu rằng bảo mật mật khẩu không chỉ là việc che giấu mật khẩu trên giao diện, mà còn là quá trình thiết kế, lưu trữ, kiểm tra và kiểm soát truy cập một cách hợp lý. Đây là kiến thức quan trọng và có tính ứng dụng cao trong quá trình xây dựng các hệ thống phần mềm an toàn.

DANH MỤC TÀI LIỆU THAM KHẢO

- [1]. OWASP Foundation, *Password Storage Cheat Sheet*, OWASP Cheat Sheet Series. Truy cập ngày 30/05/2026..
- [2]. National Institute of Standards and Technology, *NIST Special Publication 800-63B: Digital Identity Guidelines - Authentication and Lifecycle Management*. Truy cập ngày 30/05/2026.
- [3]. Microsoft, *Overview of Entity Framework Core*, Microsoft Learn. Truy cập ngày 30/05/2026.
- [4]. National Institute of Standards and Technology, *NIST to Withdraw Special Publication 800-67 Revision 2*, 2023. Truy cập ngày 30/05/2026.